

Gestión de riesgos y análisis de impacto

Módulo 2

Mauricio Bustamante Garay

Profesor

Mauricio Bustamante G.
Director Digital IT & Privacy +
Commercial
Scotiabank



Educación Universitaria:

- Científico en computación de la Universidad de Santiago de Chile
- Licenciatura en ciencias de la computación y tecnología

Certificaciones técnicas

- Fundamentos de Machine Learning UniveristiyClass Business School

Experiencia Profesional

- Mauricio Bustamante cuenta con mas de 28 años de experiencia dedicada a las tecnologías de la información.
- Como parte de las actividades que ha tenido oportunidad de ejecutar se encuentran, el Desarrollo de sistemas de gestion de datos, datawarehouse institucional y diferentes sistemas relacionados a la industria financiera
- Fue director de arquitectura empresarial liderando equipos multidisciplinarios e internacionales.
- Durante los últimos 7 años se ha desempeñado como director de Privacidad y protección de datos fomentando la cultura de riesgos de Privacidad y la evaluación de impactos de los proyectos dentro de la orgnización.
- Ha establecido el programa regional de Privacidad Empresarial y ha impulsado el Desarrollo de soluciones técnicas que apuntan a mitigar los riesgos de Privacidad dentro de la organización
- Como parte de sus actividades, también se ha dedicado a profundizar en los alcances de las leyes fintech, ciberseguridad y protección al consumidor
- Uso de inteligencia artificial y las implicaciones en la Privacidad también ha sido un foco de profundización
- Complementando las actividades profesionales, parte de su carrera la dedicó a la docencia en carreras relacionadas a las tecnologías de la información

Actividades Académicas

- Profesor de trabajos de titulación en la carrera de Ingeniería de Ejecución en Informática del IP CIISA
- Profesor de tecnologías de la información en Inacap.
- Profesor de Diplomado de Protección de Datos Personales en la Universidad de Chile

Introducción y contenidos

La Gestión de Riesgo y Análisis de Impacto de Privacidad es un curso que aborda la protección de datos personales y la privacidad en el contexto actual. En un mundo digital cada vez más interconectado, la privacidad se ha convertido en un derecho fundamental y una preocupación constante, por lo que contar con las herramientas necesarias para una correcta evaluación de sus riesgos es clave.

En este curso, exploraremos cómo evaluar y gestionar los riesgos relacionados con la privacidad en proyectos, tecnologías y programas. Entre otros temas el estudiante aprenderá a realizar Evaluaciones de Impacto de Privacidad (PIA), que son análisis exhaustivos para determinar cómo las nuevas iniciativas pueden afectar la privacidad de las personas. Estas evaluaciones proporcionan recomendaciones para minimizar o eliminar los impactos negativos y mantener un riesgo residual acorde al apetito por el riesgo de cada compañía.

OBJETIVOS ESPECÍFICOS

Durante el curso, exploraremos temas como:

- Conceptos Fundamentales de Privacidad
- Gestión de Riesgos
- Datos Personal vs Dato Sensible
- Inventario de Datos y Mapping
- Recolección y Uso de Datos
- Divulgación, Retención y Destrucción de los Datos
- Ciclo de vida de los datos
- Evaluaciones de Impacto de Privacidad (PIA)
- Casos de Estudio

Al final del curso, el alumno estará equipado con las habilidades necesarias para evaluar y gestionar los riesgos de privacidad de manera efectiva, garantizando la protección de los derechos y libertades de las personas en un mundo digital en constante evolución.

SESION 1

Introducción a la Privacidad y la gestión de sus riesgos:

- Definición de privacidad y su importancia.
- Conceptos básicos de gestión de riesgos.
- Relación entre privacidad y riesgo.
- Tipos de riesgos y su impacto en Privacidad
- Potenciales costos involucrados por riesgos de Privacidad
- Estrategias para mitigar riesgos de Privacidad.
- Monitoreo continuo y adaptación organizativa según cambios en el entorno.

¿Qué es Privacidad?

La "Privacidad" se puede definir como un estado en el que uno no es observado ni perturbado por otras personas¹. Es el derecho de mantener nuestras relaciones y asuntos personales en secreto². La privacidad nos permite crear barreras y poner límites para protegernos de interferencias no deseadas en nuestras vidas, lo que nos permite definir quiénes somos y cómo queremos interactuar con el mundo que nos rodea³.

La privacidad es esencial para quienes somos como seres humanos, y tomamos decisiones sobre ella todos los días. La privacidad nos da un espacio para ser nosotros mismos sin juicio, nos permite pensar libremente sin discriminación y es un elemento importante para dar control sobre quién sabe qué sobre nosotros.

A nivel mundial, la importancia de la privacidad es evidente en el mundo impulsado por los datos. Los individuos utilizan plataformas digitales para diversas tareas, generando cantidades sustanciales de datos personales que podrían transmitir percepciones íntimas sobre sus vidas si se utilizan incorrectamente⁶. Además, el 95% de los profesionales de seguridad en todo el mundo consideran que la privacidad es un imperativo empresarial y una parte integral de la cultura de la empresa⁹.

En Chile, el marco legal para la protección de datos se encuentra en el Artículo 19, No 4 de la Constitución Política de la República de Chile, que garantiza que el procesamiento y la protección de los datos personales se llevarán a cabo de la manera y bajo las condiciones establecidas por la ley². En un contexto global donde la opinión pública, los consumidores y los usuarios otorgan mayor importancia a la reputación de las empresas en términos de privacidad, el desarrollo por parte de las organizaciones de programas de cumplimiento certificados por sus respectivas agencias les permitió actuar más rápidamente frente a las amenazas y violaciones de seguridad¹⁴.

Por lo tanto, la privacidad es crucial tanto a nivel mundial como en Chile, ya que mantiene un límite para proteger a los usuarios de intrusiones y manipulaciones de datos no deseadas, preservando la dignidad humana y la autonomía individual.

(1) . <https://bing.com/search?q=definition+of+privacy>. (2) PRIVACY | English meaning - Cambridge Dictionary. <https://dictionary.cambridge.org/dictionary/english/privacy>. (3) What Is Privacy? | Privacy International. <https://privacyinternational.org/explainer/56/what-privacy>. (4) Privacy | Privacy International. <https://privacyinternational.org/learn/privacy>. (5) What Is Digital Privacy and Its Importance?. <https://digitalprivacy.ieee.org/publications/topics/what-is-digital-privacy-and-its-importance>. (6) Value of privacy companies global 2022 | Statista. <https://www.statista.com/statistics/1369833/privacy-importance-organizations-global/>. (7) CHAMBERS GLOBAL PRACTICE GUIDES Data Protection & Privacy 2023. https://chambers.com/downloads/gpg/770/004_chile.pdf. (8) Data Protection & Privacy. https://www.magliona.cl/wp-content/uploads/2022/03/Chambers-Data-Protection-and-Privacy_Magliona_Chile_2021.pdf. (9) Legal Alert: Chile's Bill on personal data protection: what comes ahead?. <https://www.dlapiper.cl/en/2023/05/17/legal-alert-chiles-bill-on-personal-data-protection-what-comes-ahead/>. (10) PRIVACY Definition & Meaning | Dictionary.com. <https://www.dictionary.com/browse/privacy>. (11) Privacy Definition & Meaning - Merriam-Webster. <https://www.merriam-webster.com/dictionary/privacy>. (12) Chapter 6. Privacy and data protection - OECD iLibrary. <https://www.oecd-ilibrary.org/sites/153ac49f-en/index.html?itemId=/content/component/153ac49f-en>. (13) 10 Reasons Why Privacy Matters. <https://bing.com/search?q=importance+of+privacy+worldwide>. (14) Threats to the privacy of young persons (minors) from sharenting. <https://revistaschilenas.uchile.cl/handle/2250/162349>. (15) undefined. <http://www.oxforddictionaries.com/>.

Importancia de la Privacidad

- La privacidad es importante porque la falta de ésta le otorga poder a otros sobre nosotros.
- Cuando otras personas saben demasiado sobre nosotros pueden interferir en nuestras vidas.
- La privacidad nos protege de los abusos de poder.

Por ejemplo, nos protege contra la discriminación injusta.

Si tu jefe no sabe qué religión profesas, no puede discriminar en tu contra.

La privacidad es como la venda que cubre los ojos de la justicia para que el sistema nos trate con igualdad e imparcialidad.

Ahora mismo no estamos siendo tratados como a iguales:

- No vemos el mismo contenido online,
- no nos ofrecen las mismas oportunidades
- no pagamos el mismo precio por los mismos productos

Se nos trata de acuerdo con nuestros datos (si somos mujeres u hombres, flacos o gordos, ricos o pobres) no se nos trata como a ciudadanos iguales.

Para que la democracia sea fuerte, la ciudadanía tiene que tener el control de los datos. Por eso la privacidad es una preocupación política y no solo individual.

La privacidad es poder.

Ámbitos para la vulneración de la Privacidad

- **Divulgación no consentida de información personal:**
Esto puede ocurrir cuando alguien revela información privada, como fotografías, conversaciones o datos personales
- **Vigilancia y espionaje:**
Esto puede ocurrir cuando alguien instala dispositivos de escucha, cámaras ocultas o accede a comunicaciones íntimas
- **Uso indebido de información personal**
Esto sucede cuando alguien utiliza información privada para fines maliciosos como el chantaje o difamación
- **Violación de la intimidad en el ámbito familiar**
Esto ocurre cuando un miembro de la familia invade la privacidad de otro sin consentimiento
- **Vulneración del derecho a la intimidad en entornos laborales**
Esto puede ocurrir cuando un empleador o colega accede de manera indebida a información personal de un empleado
- **Exposición mediática no autorizada**
Esto ocurre cuando los medios de comunicación divulgan información privada de una persona sin su consentimiento
- **Vulneración del derecho a la intimidad en el ámbito digital**
Esto incluye casos de robo de identidad, hackeo de cuentas personales, acoso en línea, etc.
- **Vigilancia estatal y abuso de poder**
Esto ocurre cuando el gobierno o las autoridades utilizan tecnologías de vigilancia masiva
- **Vulneración del derecho a la intimidad de personas vulnerables**
Ocurre cuando a los migrantes, refugiados o menores de edad se les vulneran de sus derechos a la intimidad

Privacidad y Protección de Datos Personales

La "Privacidad de Datos" y la "Protección de Datos" son dos conceptos que a menudo se utilizan indistintamente, pero tienen significados distintos:

- **Privacidad:** Se refiere al derecho de un individuo a controlar cómo se recopilan, utilizan y comparten sus datos personales¹. Está arraigada en el principio de consentimiento, lo que significa que cualquier recopilación, procesamiento o compartición de datos personales requiere la aprobación explícita del sujeto de los datos¹. La privacidad de datos es crucial para mantener la confianza entre individuos y organizaciones y subraya la importancia de respetar los límites personales en el ámbito digital¹.

- **Protección de Datos:** Se refiere a las medidas técnicas y administrativas implementadas para proteger los datos contra el acceso no autorizado, las violaciones y las fugas¹. Las prácticas de protección de datos, como el cifrado, los controles de acceso robustos y las evaluaciones de seguridad regulares, están diseñadas para fortalecer la confidencialidad, integridad y disponibilidad de los datos personales contra las amenazas en el ciberespacio¹.

En resumen, mientras que la privacidad de datos se ocupa de quién tiene acceso autorizado a los datos y cómo se pueden utilizar esos datos, la protección de datos se ocupa de cómo se protegen esos datos de los accesos no autorizados². Ambos conceptos son fundamentales para garantizar la seguridad y la privacidad de los datos en el mundo digital de hoy.

(1) Data Privacy vs. Protection: Key Differences Explained. <https://shinydocs.com/blog/data-privacy-vs-protection-key-differences-explained/>.

(2) Data Privacy Vs. Data Protection: Understanding The Distinction In <https://www.forbes.com/sites/forbestechcouncil/2018/12/19/data-privacy-vs-data-protection-understanding-the-distinction-in-defending-your-data/>.

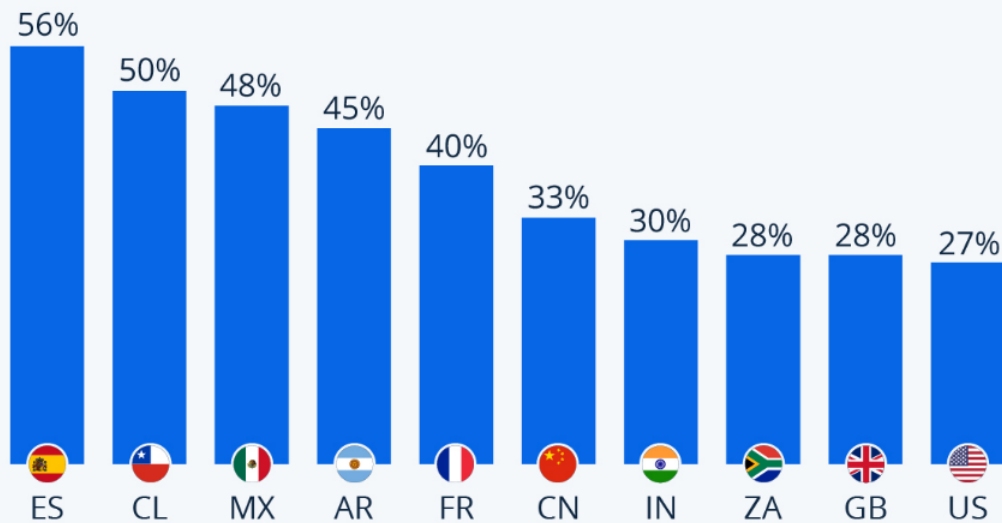
(3) Difference between data privacy and data protection. <https://www.privacy.com.sg/resources/difference-between-data-privacy-and-data-protection/>.

(4) Data Protection vs Privacy Policies | GCS Network. <https://globalcybersecuritynetwork.com/blog/data-protection-vs-data-privacy/>.

Incertidumbre por los datos en la Web

España, Chile y México, inquietos por sus datos en la web

Porcentaje de usuarios de internet a quienes les preocupa que se haga un mal uso de sus datos



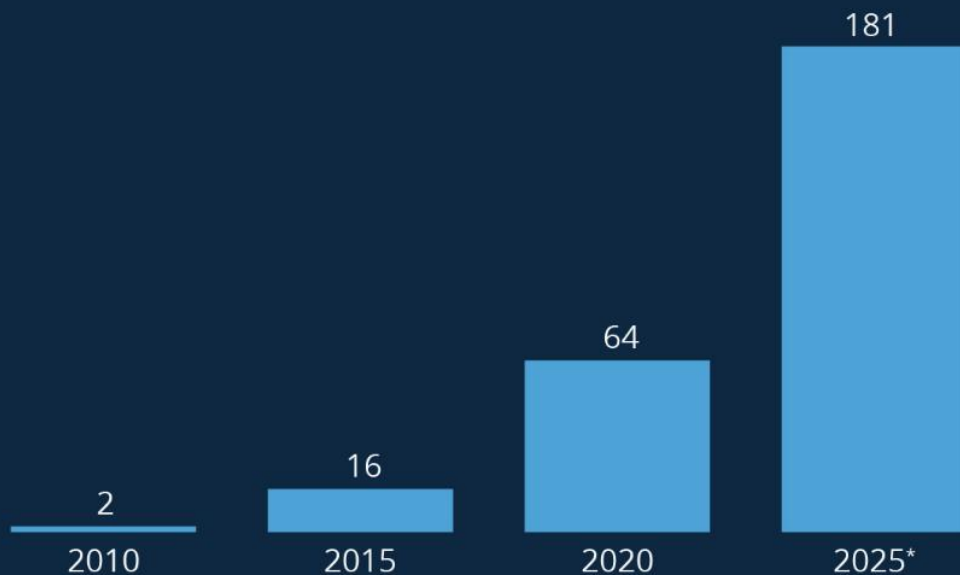
De 4.000 a 10.000 encuestados (18-64 años) online entre julio de 2022 y junio de 2023. Países seleccionados.

Fuente: Statista Consumer Insights

statista

El Big Bang del Big Data

Volumen estimado de datos digitales creados o replicados en todo el mundo, en zetabytes



Un zetabyte equivale a mil millones de gigabytes.

* Previsión de marzo de 2021.

Fuentes: IDC, Seagate, Statista

statista

Dimensionando el problema de los datos

	8 bits	1024 Bytes	1024 Kbytes	1024 MB
1bit	1 byte	1 Kilobyte	1 Megabyte	1 Gigabyte

1024 GB	1024 TB	1024 PB	1024 EB	1024 ZB
1 Terabyte	1 Petabyte	1 Exabyte	1 Zettabyte	1 Yottabyte

1024 Yottabyte
1 Brontobyte

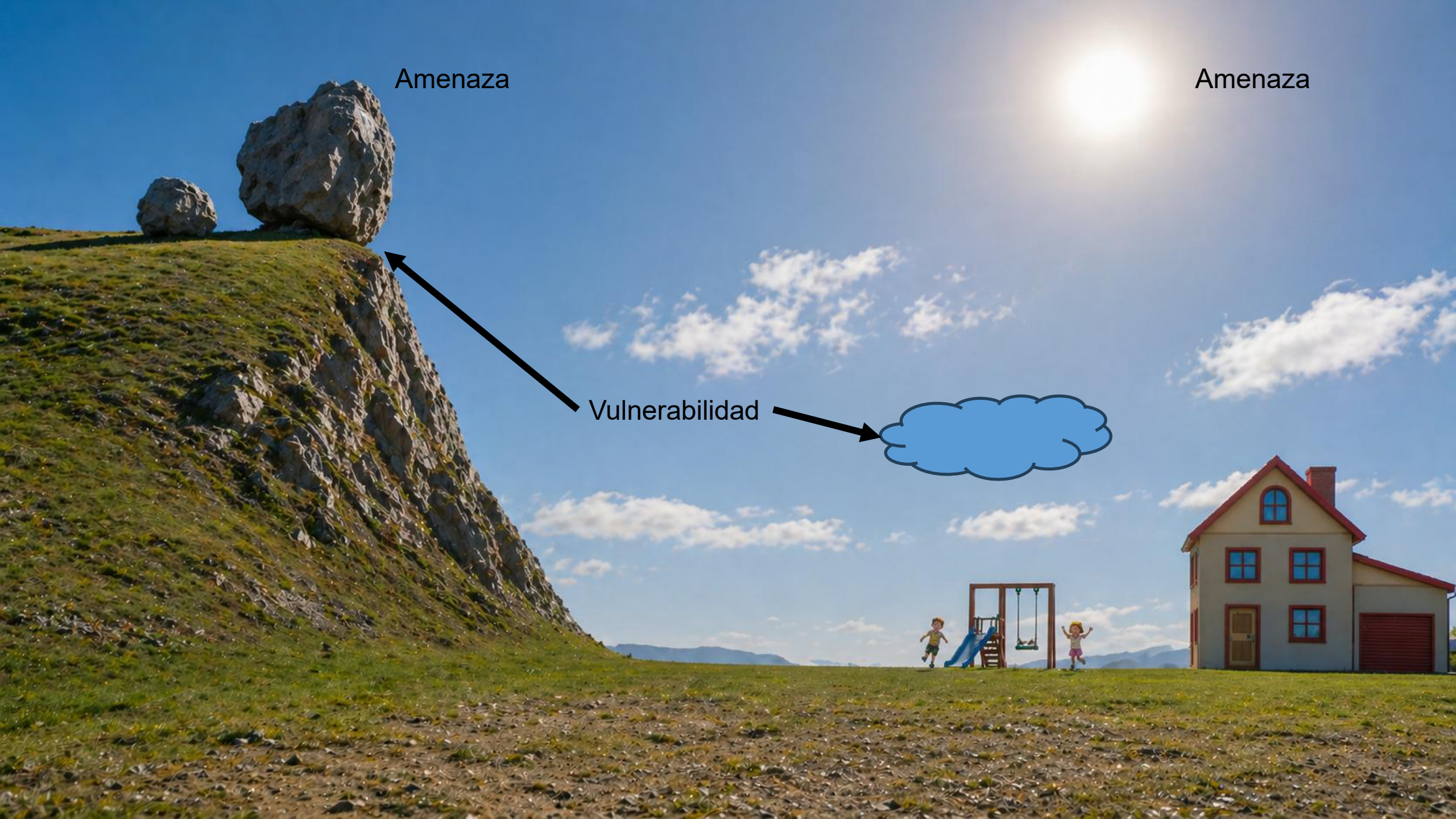
Con 181 ZB podríamos escuchar música de forma continua durante **22,5** veces la edad del Universo

Unidad	Tamaño
ZB	181
EB	185.344
PT	189.792.256
TB	194.347.270.144
GB	199.011.604.627.456
MB	203.787.883.138.515.000

1 Canción promedio en MP3	
5 MB	4 mins

Cantidad de canciones	Tiempo total a escuchar	Unidad
40.757.576.627.703.000	163.030.306.510.812.000	minutos
	2.717.171.775.180.200	horas
	113.215.490.632.508	días
	310.179.426.390	años

13.800.000.000	Edad del Universo
----------------	-------------------



Amenaza

Amenaza

Vulnerabilidad



¿Qué es un riesgo?

La palabra “riesgo” tiene una etimología interesante y algo debatida. Según el Diccionario de la Real Academia Española (DRAE), proviene del árabe “rizq” (lo que depara la providencia), a través del italiano “rischio”. Sin embargo, el filólogo Joan Corominas sugiere que “riesgo” comparte etimología con “risco” (peñasco alto), debido al peligro que enfrentan los barcos al navegar cerca de estos lugares. Ambas palabras podrían derivar del latín “resecare” (cortar, dividir), relacionado con el concepto de peligro.

La Real Academia de la Lengua, lo define como: Contingencia o proximidad de un daño. Riesgo es la vulnerabilidad ante un potencial perjuicio o daño para las unidades, personas, organizaciones o entidades.

Una buena manera darle forma a la definición de riesgos es a través de dos dimensiones: Amenaza y Vulnerabilidad.

Una amenaza es un fenómeno, sustancia, actividad humana o condición peligrosa que puede ocasionar la muerte, lesiones u otros impactos a la salud, al igual que daños a la propiedad, la pérdida de medios de sustento y de servicios, trastornos sociales y económicos, o daños ambientales. Las amenazas se determinan en función de la intensidad y la frecuencia.

Por otro lado, una vulnerabilidad son las características y las circunstancias de una comunidad, sistema o bien que los hacen susceptibles a los efectos dañinos de una amenaza.

RIESGO = AMENAZA x VULNERABILIDAD o de otra manera RIESGO = PROBABILIDAD x IMPACTO.

Escala de Probabilidades vs Impacto

Probabilidad despreciable: La posibilidad de ocurrencia es muy baja (por ejemplo, un evento que puede pasar de forma fortuita).

Probabilidad limitada: La posibilidad de ocurrencia es baja (por ejemplo, un evento que puede pasar de forma ocasional).

Probabilidad significativa: La posibilidad de ocurrencia es alta (por ejemplo, un evento que puede pasar con bastante frecuencia).

Probabilidad máxima: La posibilidad de ocurrencia es muy elevada (por ejemplo, un evento cuya ocurrencia se produce con mucha frecuencia)

Impacto despreciable: El impacto es muy bajo (por ejemplo, un evento cuyas consecuencias son prácticamente despreciables sin impacto sobre el interesado).

Impacto limitado: El impacto es bajo (por ejemplo, un evento cuyas consecuencias implican un daño menor sin impacto relevante sobre el interesado).

Impacto significativo: El impacto es alto (por ejemplo, un evento cuyas consecuencias implican un daño elevado con impacto sobre el interesado).

Impacto máximo: El impacto es muy alto (por ejemplo, un evento cuyas consecuencias implican un daño muy elevado un impacto crítico sobre el interesado)

Probabilidad	Máxima 4	4	8	12	16
	Significativa 3	3	6	9	12
	Limitada 2	2	4	6	8
	Despreciable 1	1	2	3	4
		Despreciable · 1 Limitada · 2 Significativa · 3 Máxima · 4			
		IMPACTO			

Bajo

Medio

Alto

Muy Alto



Vulnerabilidad
se mantiene

Riesgo Inherente

Es el riesgo intrínseco de cada actividad, sin tener en cuenta los controles que de éste se hagan a su interior. Este riesgo surge de la exposición que se tenga a la actividad en particular y de la probabilidad que un choque negativo afecte la rentabilidad y el capital de la compañía.

El riesgo inherente es propio del trabajo o proceso, que no puede ser eliminado del sistema; es decir, en todo trabajo o proceso se encontrarán riesgos para las personas o para la ejecución de la actividad en sí misma.

Algunos ejemplos:

Transporte: Choques, colisiones, volcamiento

Metalmecánica: Quemaduras, golpes

Minería: Derrumbes, explosiones, caídas, atrapamiento, asfixia

En auditoría, "Riesgo inherente" es la susceptibilidad del saldo de una cuenta o clase de transacciones a una representación errónea que pudiera ser de importancia relativa, individualmente o cuando se agrega con representaciones erróneas en otras cuentas o clases, asumiendo que no hubo controles internos relacionados. Un riesgo inherente es uno que se encuentra en el ambiente y afecta a varias categorías o clases de transacciones.

Riesgo Residual

Es aquel riesgo que subsiste, después de haber implementado controles. Es importante advertir que el nivel de riesgo al que está sometido una compañía nunca puede erradicarse totalmente. Por ello, se debe buscar un equilibrio entre el nivel de recursos y mecanismos que es preciso dedicar para minimizar o mitigar estos riesgos y un cierto nivel de confianza que se puede considerar suficiente (nivel de riesgo aceptable). El riesgo residual puede verse como aquello que separa a la compañía de la seguridad absoluta.

El riesgo residual es aquél que permanece después de que la dirección desarrolle sus respuestas a los riesgos. El riesgo residual refleja el riesgo remanente una vez se han implantado de manera eficaz las acciones planificadas por la dirección para mitigar el riesgo inherente.

Estas acciones pueden incluir las estrategias de diversificación relativas a las concentraciones de clientes, productos u otras, las políticas y procedimientos que establezcan límites, autorizaciones y otros protocolos, el personal de supervisión para revisar medidas de rendimiento e implantar acciones al respecto o la automatización de criterios para estandarizar y acelerar la toma de decisiones recurrentes y la aprobación de transacciones. Además, pueden reducir la probabilidad de ocurrencia de un posible evento, su impacto o ambos conceptos a la vez.

Ejemplo 1

Supongamos una aplicación móvil con almacenamiento en la nube, que captura datos a través de wearables (dispositivos como un reloj o pulsera), entre otras cosas permite la introducción manual de datos de salud por parte del usuario. La finalidad de la actividad de tratamiento es monitorizar la actividad del usuario y recomendar hábitos de vida saludables. La aplicación móvil no dispone de medidas de control de acceso, ni de detección de malware, además no se realizan copias de seguridad de los datos. Adicionalmente, durante la fase de registro del usuario no se solicita consentimiento expreso para ninguna finalidad adicional a la mencionada. Ante este contexto, se puede identificar, entre otras, varias amenazas y riesgos asociados que se describen y evalúan a continuación:

Ejemplo 1: Matriz de riesgos

Tipo amenaza	Amenaza	Riesgo	Probabilidad	Impacto	Riesgo inherente
Acceso ilegítimo a los datos	Fuga de información (derivada de la pérdida del dispositivo móvil)	Acceso no autorizado a datos personales, incluyendo datos sensibles de salud. Puede implicar responsabilidad del responsable del tratamiento por no aplicar medidas técnicas y organizativas adecuadas	Significativa 3	Significativo 3	Alto 9
	Operación de tratamiento no autorizada (derivada del uso de los datos para una finalidad sin base legitimadora, por ejemplo, acciones de marketing indirecto sobre productos de salud)	Uso ilícito de datos personales sin una base de legitimación válida (como consentimiento, obligación legal u otra), vulnerando los principios de licitud, finalidad y proporcionalidad establecidos en la Ley 21.719.	Máxima 4	Limitado 2	Alto 8
Modificación no autorizada de los datos	Ataque cibernético (malware que modifica los datos almacenados en la nube)	Modificación no autorizada de datos personales que compromete su integridad, incumpliendo el deber de seguridad de la Ley 21.719.	Significativa 3	Limitado 2	Medio 6
	Operación de tratamiento no autorizada (derivada de una decisión automatizada en base al perfilado de datos erróneo por una mala programación del software , por ejemplo, una categorización de personas saludables con acceso a determinadas coberturas de un seguro de salud)	Uso de datos incorrectos en procesos automatizados (profiling) que afecta derechos de los titulares (por ejemplo, discriminación o decisiones injustas), vulnerando el derecho a la exactitud de los datos y a no ser objeto de decisiones automatizadas sin garantías.	Máxima 4	Significativo 3	Muy alto 12
Eliminación de los datos	Corte de suministro eléctrico o fallos en servicios de comunicaciones (como consecuencia del fallo se produce un periodo temporal en el cual los datos no han sido almacenados)	Pérdida o indisponibilidad temporal de datos personales, afectando el principio de disponibilidad y continuidad del tratamiento según la ley 21.719.	Limitada 2	Limitado 2	Medio 4
	Ataque intencionado que provoca la indisponibilidad de los datos (como consecuencia de un ataque de cifrado de las bases de datos que inhabilita las mismas)	Pérdida o bloqueo de acceso a datos personales debido a ataques maliciosos, vulnerando el principio de disponibilidad. Incumplimiento del deber de implementar medidas de seguridad robustas y posibles sanciones.	Significativa 3	Significativo 3	Alto 9

Ejercicio 1

Supongamos que una empresa adquiere un sistema de marcación de asistencia. El sistema tiene la funcionalidad de controlar la asistencia a través del mecanismo de huella dactilar o, en aquellos casos de personas que tengan modalidad de trabajo remoto, de registrar la asistencia a través del celular. Ninguno de los mecanismos utiliza técnicas de encriptación ni en tránsito ni en reposo, lo que significa que la huella o la clave viajan y se almacenan en “claro” (quedando expuesta).

El sistema es una solución SaaS y su base de datos también se encuentra en cloud.

El proveedor no tiene una certificación de seguridad ISO o NIST

Identifica los riesgos inherentes, relacionados a privacidad y datos personales involucrados.

Ejercicio 2

Una empresa del retail adquiere un sistema que es capaz de recopilar, en tiempo real, la actividad y acciones que realiza un cliente en el sitio web. Un proceso de IA establece preferencias y patrones de compra del cliente con el fin de ofrecer productos a medida y acorde a lo que la IA va determinando. Este sistema funciona de forma background y para el cliente pasa inadvertida toda esta funcionalidad.

El proveedor es altamente reconocido a nivel de la industria, cumple los más altos estándares internacionales de seguridad, basado en la norma ISO 27.001, además cuenta con certificaciones vigentes de seguridad y cifrado extremo a extremo, incluyendo el cifrado en reposo de doble entrada.

Identifica los riesgos inherentes, relacionados a privacidad y datos personales involucrados.

- Riesgos de privacidad desde la mirada del titular
- Riesgos de privacidad desde la mirada de la organización

Riesgos de Privacidad del titular

1. **Redes sociales:** Las redes sociales recopilan una gran cantidad de información personal que puede ser utilizada para fines publicitarios y, en algunos casos, puede ser vendida a terceros. Entre la información está la relativa a la vida íntima del individuo.
2. **Compras en línea:** Al realizar compras en línea, se comparte información financiera y personal que podría ser interceptada o mal utilizada. Sin embargo, también se pueden crear patrones de gustos y/o preferencias relacionado con la vida íntima del individuo.
3. **Comunicaciones electrónicas:** Los correos electrónicos, mensajes de texto y llamadas pueden ser interceptados y monitoreados, lo que puede llevar a una invasión de la privacidad y vida personal.
4. **Dispositivos inteligentes:** Los dispositivos inteligentes, como los teléfonos móviles y los altavoces inteligentes, recopilan datos personales y de ubicación que pueden ser utilizados para crear perfiles detallados de los usuarios. Una invasión a la vida personal de los titulares.
5. **Aplicaciones móviles:** Muchas aplicaciones móviles recopilan datos personales, incluyendo la ubicación, que pueden ser compartidos con terceros. Estas ubicaciones pueden formar patrones de movimientos que permitan conocer parte de la vida privada de las personas.
6. **Búsquedas en línea:** Las búsquedas en línea pueden ser rastreadas y utilizadas para crear perfiles de usuario, lo que puede llevar a una invasión de la privacidad.
7. **Cámaras de seguridad:** Las cámaras de seguridad pueden invadir la privacidad si capturan imágenes sin el consentimiento del individuo.
8. **Datos de salud:** Los datos de salud pueden ser compartidos o vendidos sin el consentimiento del individuo, lo que puede llevar a una invasión de la privacidad.
9. **Información financiera:** La información financiera puede ser robada o mal utilizada, dejando expuesta la vida financiera de los titulares de datos.

Los actores del riesgo en una empresa

1. Clientes
2. Ex-Clientes
3. Prospectos
4. Leads
5. Relacionados
 - Socios, Directores, Avaless, Garantes, etc.
6. Colaboradores
7. Ex-Colaboradores
8. Postulantes
9. Titulares en general (Compra de datos)

Categorías de Riesgos de Privacidad

1. **Riesgo reputacional:** El uso inadecuado de la información personal, fuga o exposición no autorizada de información puede llevar a que las organizaciones sean sometidas al escrutinio público y mediático, haciendo que su reputación sea afectada de manera significativa. Ej. ¿Qué pasaría si una compañía compra o provee datos a Cambridge Analytics?
2. **Riesgo legal:** Dependiendo del tamaño de las empresas, tener juicios masivos o colectivos puede significar un impacto importante que incluso ponga en peligro su continuidad en el mercado. Ej: ¿Qué pasa si sale a la luz que una compañía trata los datos de las personas sin consentimiento?
3. **Riesgo operacional:** Entre los derechos de los titulares se encuentra el de oposición, el cual obliga, bajo ciertas condiciones, dejar de tratar o procesar la información. Pueden darse escenarios en que las empresas se vean impedidas de operar normalmente afectando gravemente su negocio y utilidades.
4. **Riesgo financiero:** Los costos colaterales de muchos de los riesgos mencionados en esta lista, pueden llevar a las empresas a perder muchísimo dinero, disminuyendo las utilidades y poniendo en riesgo la confianza de inversionistas o socios.
5. **Riesgo de cumplimiento:** No cumplir con la normativa vigente puede exponer a las empresas a multas por parte de los reguladores y con ello riesgo de auditorías y clasificaciones negativas que afecten la reputación y la confianza del mercado.
6. **Riesgo de terceros:** Una gestión inadecuada de los riesgos de terceros puede poner consecuentemente en riesgo a la propia compañía, gatillando uno o varios de los riesgos antes mencionados.

Los seis principales disparadores

1. **Pocos controles sobre los datos**: La falta de controles in place o derivados sobre los componentes tecnológicos y sobre la infraestructura, tanto de terceros como propios, es el principal riesgo de pérdida uso indebido de los datos personales.
2. **Sesgo o errores en el modelamiento de datos**: El uso inadecuado de datos personales como la edad, el sexo u otros similares, en los modelos predictivos, de prospectación, de riesgo, etc. Podría llevar a discriminación lo que podría afectar a la persona en su vida personal.
3. **La no existencia de compliance**: Una empresa debe estar continuamente preocupada de cumplir las obligaciones normativas y legales respecto al uso y tratamiento de datos personales, no hacerlo podría acarrear grandes riesgos de cumplimiento.
4. **La falta de cultura y concientización en las organizaciones**: Está demostrado que la falta de concientización dentro de una empresa es uno de los factores más importantes en el mal uso y tratamiento de datos personales.
5. **La falta de políticas, estándares, procedimientos, programas o frameworks**: No contar con estándares y directrices que regulen tanto el comportamiento de las personas como la administración del riesgo (de privacidad u otros) puede traer un impacto negativo en las organizaciones.
6. **La falta de inversión**: No invertir tanto en ciberseguridad, cumplimiento, tecnología, etc. Es uno de los errores que debilita las barreras y hace que los riesgos se materialicen con mayor facilidad.

Elementos recurrentes a considerar en Privacidad

Consentimiento	Proporcionalidad	Minimización
Retención	Borrado	Legitimidad
Exposición	Fuga	Trasparencia
Propagación	ARCO	Protección
Sesgo de datos	Malas decisiones	Sensibilidad

Tratamiento o respuesta ante los riesgos

La última etapa del proceso de gestión de riesgos consiste en definir la respuesta o las medidas necesarias para tratar el riesgo y reducir su nivel de exposición. Tratar un riesgo es el resultado de definir y establecer medidas de control para disminuir la probabilidad y/o el impacto asociado al riesgo inherente de una operación de tratamiento. ¿Qué alternativas existen para reducir o mitigar un riesgo? El nivel de riesgo se puede tratar con el objetivo de reducir o mitigar el mismo, en función de la medida que se adopte. Existen cuatro medidas diferentes para tratar el riesgo:

Reducción del riesgo: Para reducir el nivel de riesgo, se deben establecer medidas de control que reduzcan los niveles de probabilidad y/o impactos asociados al riesgo inherente.

Retención del riesgo: Si el nivel de riesgo inherente es inferior al nivel de riesgo considerado como aceptable, no existe necesidad de implementar controles adicionales.

Transferencia del riesgo: Consiste en compartir un riesgo con una organización externa. Se puede transferir el riesgo a una aseguradora que afronte las posibles consecuencias materiales. Sin embargo, se ha de considerar que, en ocasiones, la transferencia de riesgos puede generar otros riesgos. Por ello, la transferencia puede generar la necesidad de análisis adicionales.

Anulación del riesgo: Si el riesgo es muy elevado y no se quiere asumir el mismo, se puede decidir abandonar la actividad de tratamiento.

Controles sobre los Riesgos de datos

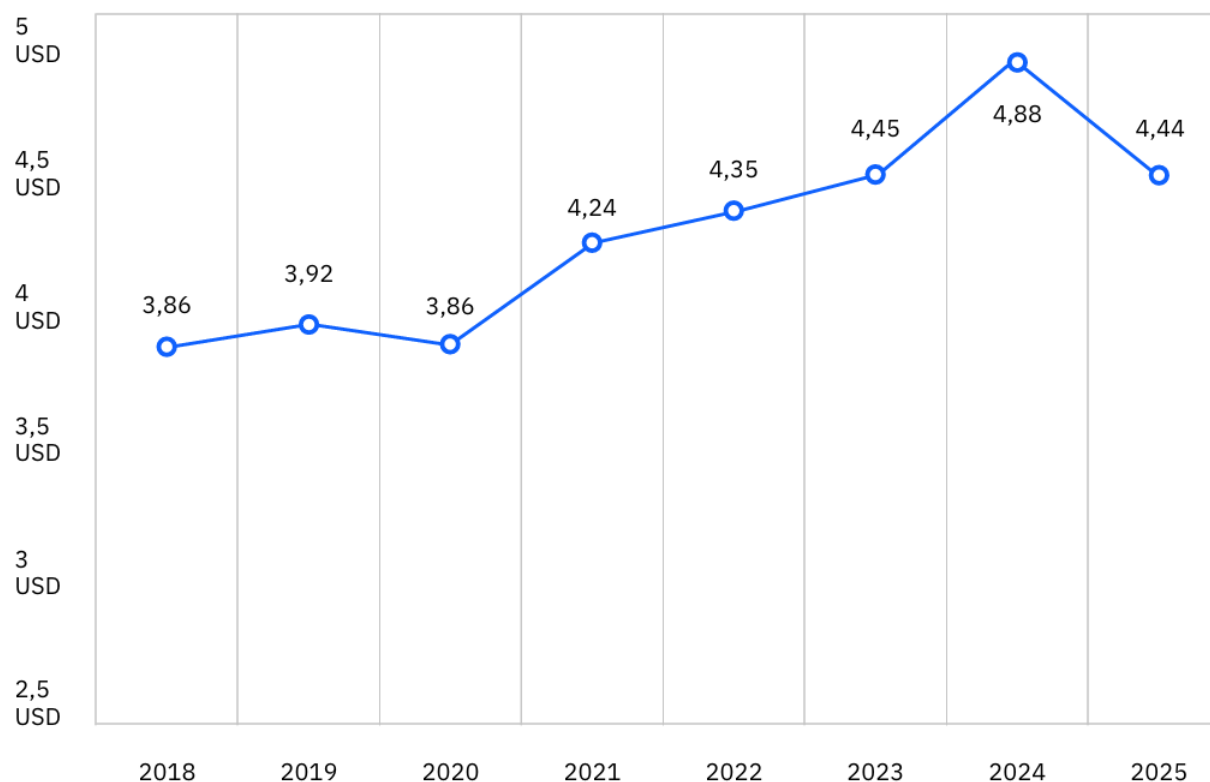
1. **Controles para evitar persistencia innecesaria:** La persistencia de información puede materializarse tanto de forma digital como física. Contar con políticas de escritorios limpios y de trituración/disposición de documentación es un control efectivo. Así mismo, contar con procesos automáticos de borrado de registros digitales ayudará a mantener un flujo sano y de bajo riesgo en las organizaciones.
2. **Controles para evitar fisgoneo:** Una correcta administración de perfiles y accesos a los sistemas tecnológicos suele ser uno de los controles más efectivos, aunque no el único, para evitar el fisgoneo.
3. **Controles para evitar fraude:** Los procedimientos respecto a segregación de funciones y los perfilamientos por atribución ayudan a mitigar los riesgos de fraude interno en las empresas.
4. **Controles para evitar la duplicidad:** La duplicidad de fuentes de datos o de elementos de datos es señal de ausencia de gobierno. El gobierno de datos es un socio clave en la mitigación de riesgos de duplicidad de información.
5. **Controles para mantener la información actualizada:** Procedimientos de control de calidad y ciclo de vida de la información es fundamental para mitigar el riesgo de información desactualizada.
6. **Controles para evitar la propagación:** Tanto el gobierno de datos como los controles de acceso son elementos fundamentales para mantener a raya los índices de propagación de datos en una empresa.

La materialización de los riesgos tiene consecuencias, las consecuencias tienen costos y los costos excesivos dañan el patrimonio de las empresas

Costo de una brecha de datos 2025

El costo promedio de una Brecha de datos se ha ido incrementando consistentemente en el tiempo.

Figura 1.
Medido en millones de dólares estadounidenses



Costo de una brecha de datos 2025

Latinoamérica está en la posición 10 de las regiones con mayor costo por brecha de datos

#	País		2025	2024
1	Estados Unidos	↑	10,22 USD	9,36 USD
2	Oriente Medio	↓	7,29 USD	8,75 USD
3	Benelux	↑	6,24 USD	5,90 USD
4	Canadá	↑	4,84 USD	4,66 USD
5	Reino Unido	↓	4,14 USD	4,53 USD
6	Alemania	↓	4,03 USD	5,31 USD
7	Latinoamérica	↓	3,81 USD	4,16 USD
8	Francia	↓	3,73 USD	4,17 USD

#	País		2025	2024
9	ASEAN	↑	3,67 USD	3,23 USD
10	Japón	↓	3,65 USD	4,19 USD
11	Italia	↓	3,44 USD	4,73 USD
12	Corea del Sur	↓	2,84 USD	3,62 USD
13	Australia	↓	2,55 USD	2,78 USD
14	India	↑	2,51 USD	2,35 USD
15	Sudáfrica	↓	2,37 USD	2,78 USD
16	Brasil	↓	1,22 USD	1,36 USD

Costo de una brecha de datos 2025

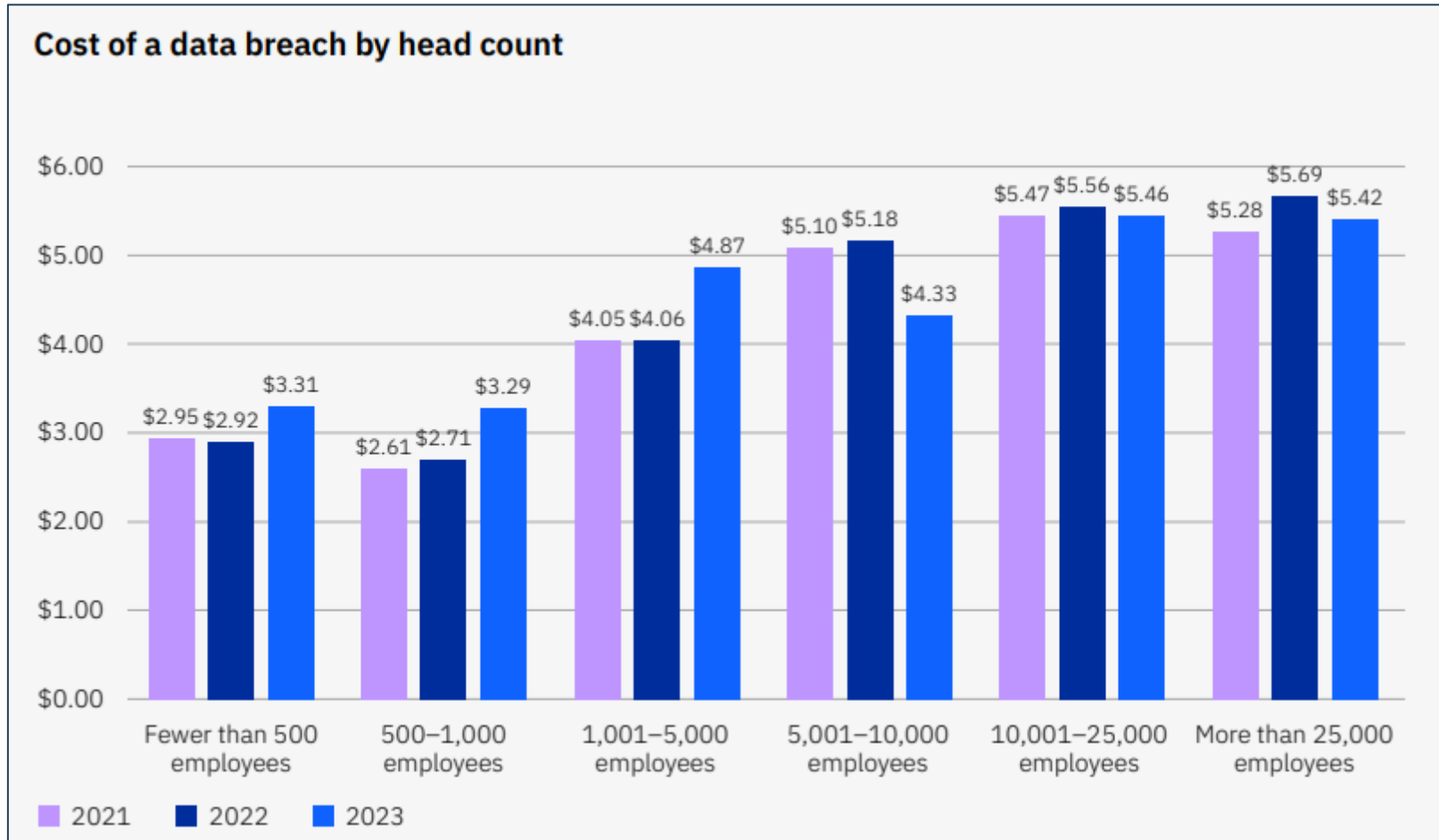
Rubro de salud y la industria financiera entre los costos más elevados.

Figura 3.
Medido en millones de dólares estadounidenses



Costo de una brecha de datos 2023

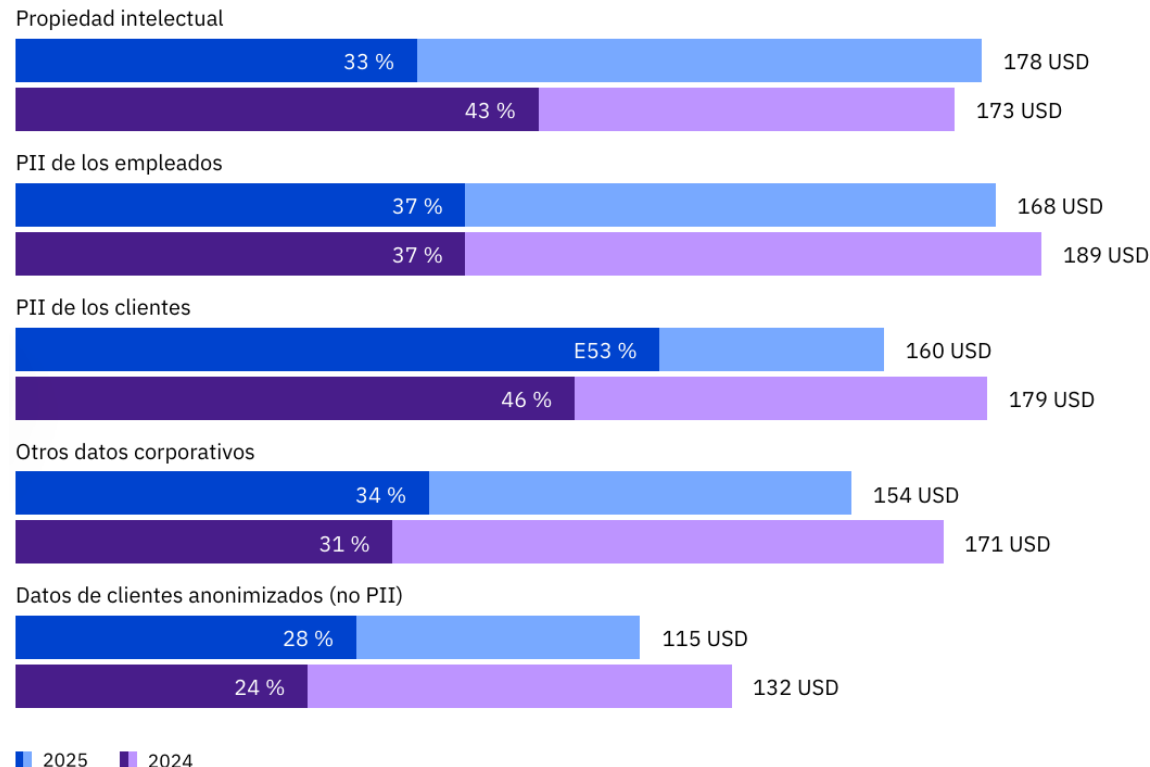
Empresas más pequeñas han incrementado los costos por brecha en el último año



Costo de una brecha de datos 2025

La topología más comprometida en las brechas de datos es la de datos personales (PII) de clientes, cifra que se ha ido incrementando consistentemente año tras año

Figura 6.
Medido en USD; se permite más de una respuesta

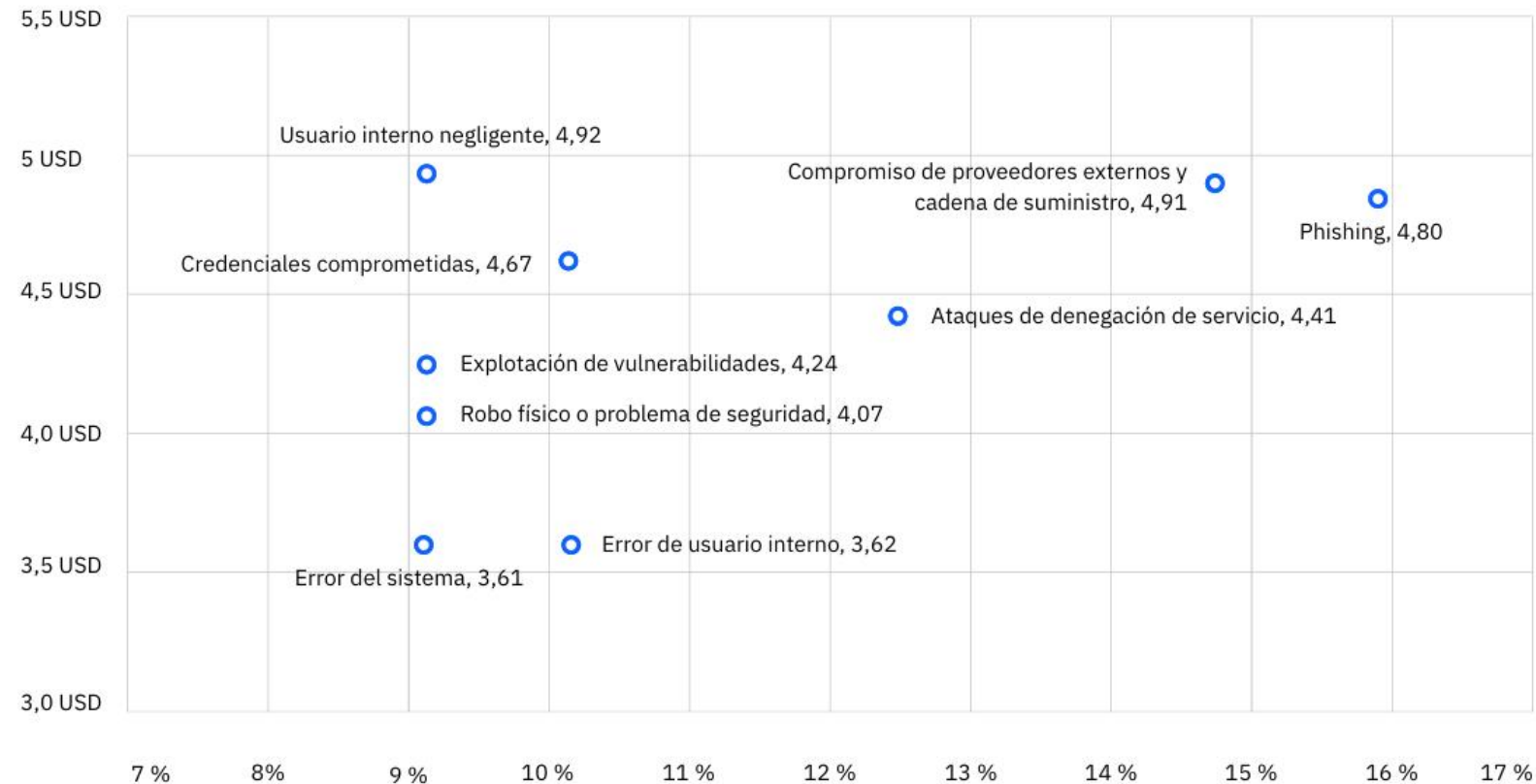


La mayoría de las vulneraciones se dirigieron a la PII de los clientes
Los atacantes se centraron en la PII de los clientes por encima de otros tipos de datos por un amplio margen. Con un 53 %, fue el tipo de datos más robado o comprometido. La PII de los clientes puede incluir números de identificación fiscal, correos electrónicos y direcciones particulares, y puede utilizarse para el robo de identidad y el fraude con tarjetas de crédito. Por otro lado, la propiedad intelectual (PI) de las empresas, aunque menos susceptible de ser robada o comprometida, fue la más costosa (178 USD por registro). Véase la Figura 6.

Costo de una brecha de datos 2025

El Phishing y el robo de credenciales son los vectores de ataque más comunes

Figura 9.
Medido en millones de dólares; porcentaje del total de vulneraciones



Costo de una brecha de datos 2024

Entrenamiento y no compliance entre los factores que encarecen o mitigan el costo de un data breach respectivamente (sin considerar los factores de seguridad)

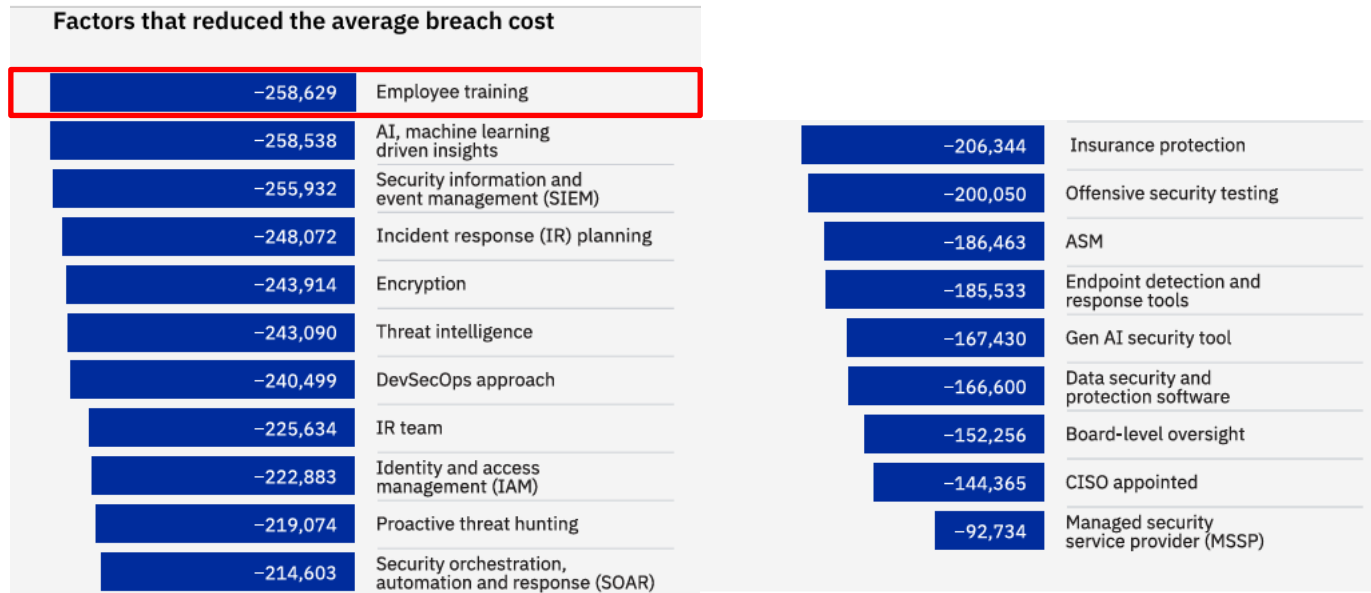


Figure 25. Cost difference from USD 4.88M breach average; measured in USD

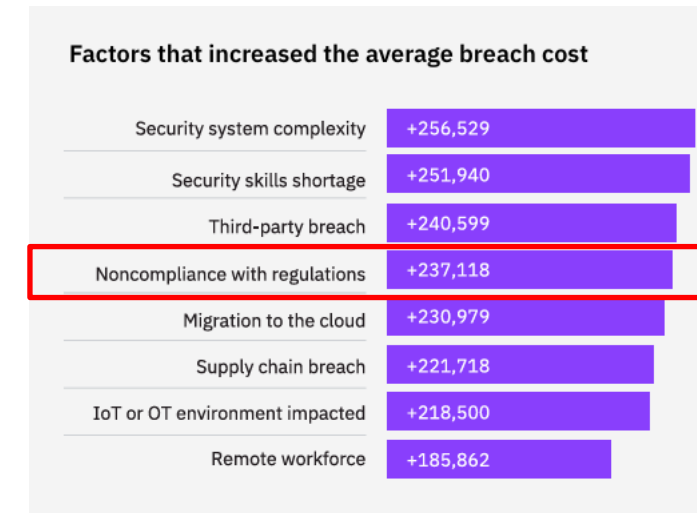


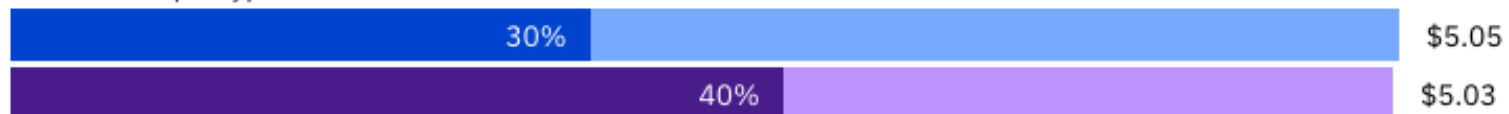
Figure 26. Cost difference from USD 4.88M breach average; measured in USD

Costo de una brecha de datos 2025

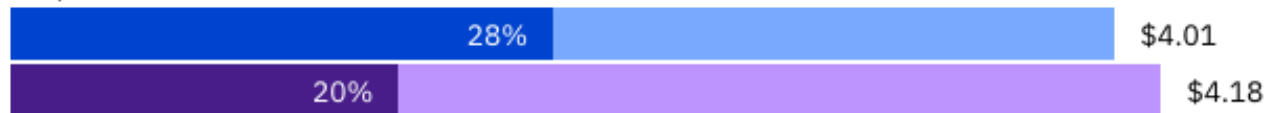
Costo de una brecha de datos dependiendo del lugar de almacenamiento de los datos

Figure 7.
Measured in USD millions; more than one response permitted

Across multiple types of environments



On premises



Public cloud



Private cloud



■ 2025 ■ 2024